

Vers une infrastructure publique sans secrets statiques

Proposition d'expérimentation d'une architecture
française d'identités cryptographiques, de secrets et de
credentials éphémères

Biscuits IA — Document de proposition technique
Août 2026

Version 1.0

1. Résumé exécutif

Le problème : Les infrastructures publiques critiques s'appuient historiquement sur des secrets statiques (mots de passe, clés d'API permanentes, comptes de service persistants). Une compromission de ces éléments offre aux attaquants un accès persistant, souvent difficile à détecter, créant une vulnérabilité systémique.

La solution : Réduire drastiquement la surface d'attaque en basculant d'un modèle basé sur la connaissance d'un secret à un modèle basé sur la preuve cryptographique de l'identité, couplée à des autorisations dynamiques et temporelles.

Le prototype : Biscuits IA, association à but non lucratif (loi 1901), a développé une architecture expérimentale intégrant des identités cryptographiques (Passkeys/FIDO2), un moteur de politiques d'accès (Policy Engine), et la génération de *credentials* éphémères juste-à-temps (JIT) via un gestionnaire de secrets et des modules matériels de sécurité (HSM).

Les bénéfices : Limitation du risque d'élévation de privilèges, obsolescence programmée et automatique des identifiants volés, traçabilité exhaustive et cloisonnement renforcé des environnements sensibles.

La proposition : Mettre à disposition ce prototype pour évaluation au sein de l'écosystème institutionnel de cybersécurité français.

Niveau de maturité : Prototype technique fonctionnel (Proof of Concept), nécessitant des revues de code indépendantes, des tests d'intrusion et une évaluation en conditions réelles non critiques.

Prochaine étape : Définir un périmètre d'expérimentation pilote avec une administration ou une entité publique volontaire.

« Nous ne demandons pas que cette architecture soit adoptée sur la base de notre seule démonstration. Nous proposons qu'elle soit testée, auditée et confrontée à la réalité opérationnelle. »

2. Le problème

L'hygiène de sécurité des systèmes d'information s'est considérablement améliorée au cours de la dernière décennie. Néanmoins, une faille conceptuelle subsiste : la dépendance structurelle aux secrets statiques. Ces secrets, parce qu'ils sont durables, deviennent des cibles de haute valeur pour les attaquants.

Les limites structurelles actuelles

- **Mots de passe et secrets partagés** : Voici le risque : ils sont vulnérables au vol, au phishing et aux fuites de bases de données. Voici pourquoi il persiste : l'infrastructure legacy exige souvent une authentification par chaîne de caractères. Voici ce que notre approche cherche à changer : supprimer la connaissance du secret au profit d'une vérification asymétrique.
- **Comptes privilégiés permanents** : Un compte "Administrateur" existe 24h/24, même lorsqu'il n'est pas utilisé. En cas de compromission du poste, ce compte est immédiatement exploitable. Notre approche limite le privilège au moment strict de l'intervention.
- **Clés API longue durée et configurations** : De nombreuses applications authentifient leurs échanges via des clés inscrites en dur dans le code ou des variables d'environnement. Leur rotation est complexe et rare, entraînant un risque de fuite prolongée.
- **Accès fournisseurs persistants** : Les prestataires externes disposent souvent d'accès VPN ou de comptes dédiés qui restent ouverts hors des fenêtres de maintenance.

3. Pourquoi le MFA n'est pas la destination finale

Il est fondamental de préciser un fait : l'authentification multifacteur (MFA) n'est pas obsolète ni défaillante. C'est une excellente protection de première ligne. Cependant, le MFA traditionnel (OTP, SMS, Push) vient souvent colmater les failles d'un système qui reste fondamentalement basé sur un secret partagé (le mot de passe).

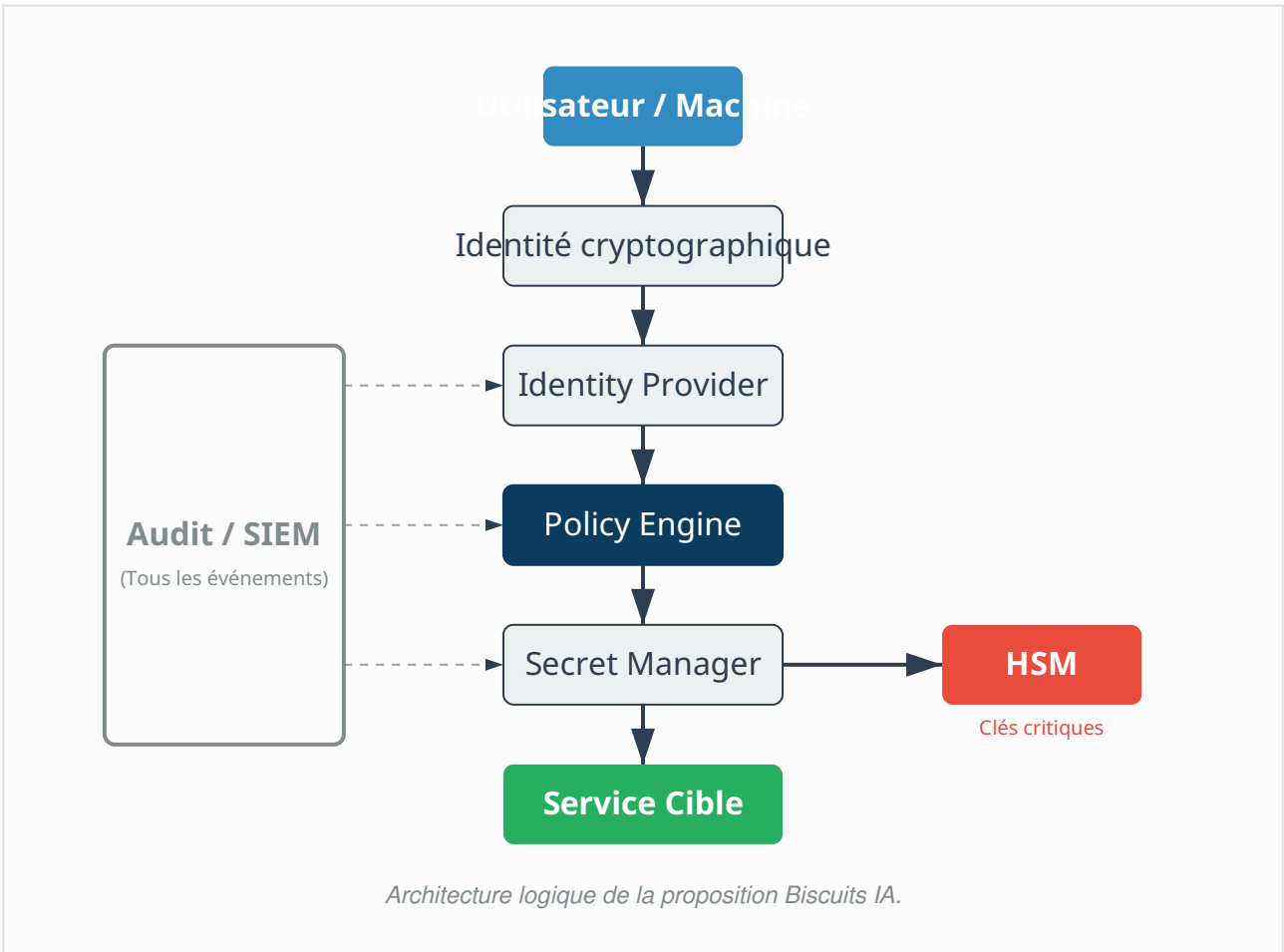
Le MFA renforce une architecture fondée sur l'identité et le secret ; l'approche *passwordless* et cryptographique cherche à réduire la dépendance au secret humain lui-même.



L'objectif de ce document n'est pas de prétendre que le MFA doit disparaître partout, mais de présenter cette évolution technologique comme la nouvelle norme souhaitable pour les accès privilégiés et les environnements critiques.

4. Notre proposition

L'architecture proposée par Biscuits IA repose sur la décentralisation de la confiance et la temporalité des accès. Chaque composant vérifie l'intégrité de la demande avant de délivrer un sésame éphémère.



5. Architecture technique

Le prototype s'articule autour de quatre piliers technologiques interdépendants, garantissant une défense en profondeur.

1. Gestion des Identités (Identity)

- **FIDO2 / WebAuthn & Passkeys** : L'authentification initiale ne repose plus sur un mot de passe, mais sur un protocole d'authentification asymétrique résistant par conception au phishing.
- **Certificats & Identités machines** : Les services s'authentifient via des certificats X.509 de courte durée (mTLS).

2. Gestion des Accès (IAM & PAM)

- **RBAC & ABAC** : Politiques basées sur les rôles et sur le contexte (heure, localisation, état de conformité du poste).
- **Just-In-Time (JIT) access & Just Enough Privilege (JEP)** : Les comptes privilégiés ne sont créés ou activés qu'à la volée, suite à une approbation valide, pour la durée stricte de l'opération.

3. Gestion des Secrets (Secrets Management)

- **Génération dynamique** : Les mots de passe de bases de données ou les tokens d'API sont générés dynamiquement par le Secret Manager lors de la requête et expirent automatiquement.
- **Rotation & Révocation** : Procédures automatisées permettant de purger les accès en quelques millisecondes.

4. Cryptographie & Audit

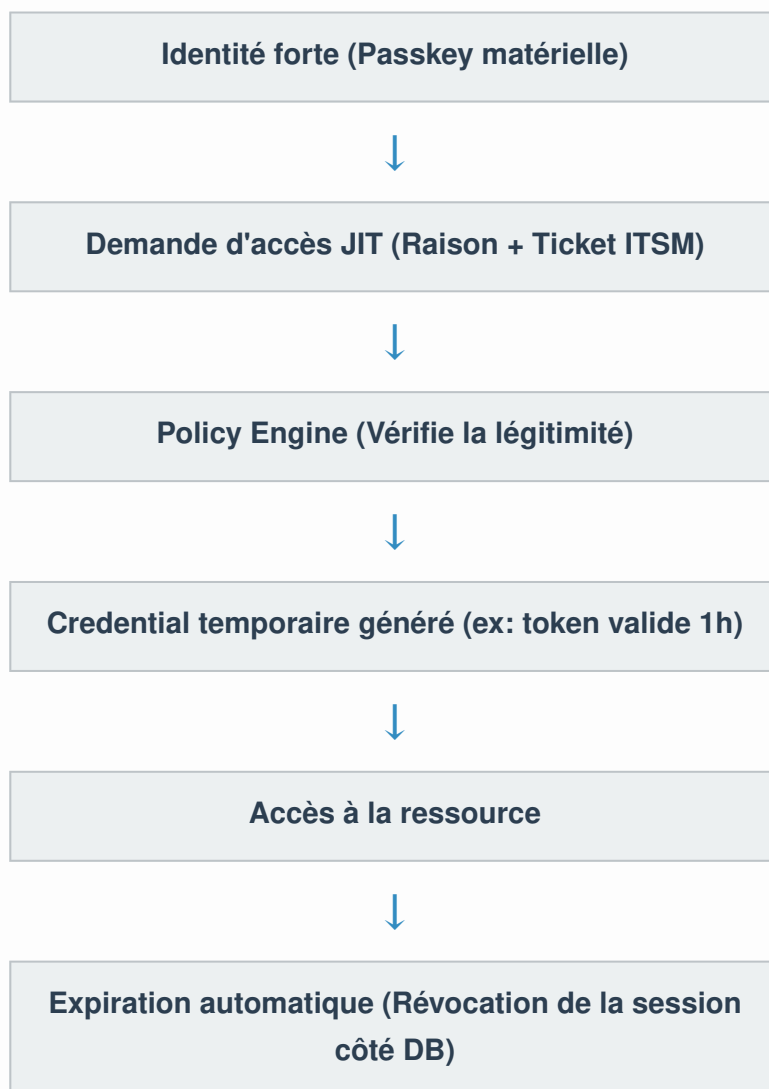
- **HSM (Hardware Security Module)** : Ségrégation matérielle des clés maîtresses.
- **SIEM & Traçabilité** : Journalisation inaltérable de chaque génération de credential, permettant une analyse forensic immédiate en cas de comportement anormal.

6. Exemple concret

Situation actuelle (Legacy)

Un administrateur de base de données (ou un microservice) utilise un compte `admin_db` avec le mot de passe `SuperSecret2026!`. Ce secret est configuré dans le client SQL ou le fichier `.env` du service. Si ce poste ou ce serveur est compromis, l'attaquant récupère le secret en clair. Ce secret restera valable pendant des mois, permettant à l'attaquant de s'y connecter de manière persistante, de nuit, depuis une autre machine.

Avec l'architecture proposée



Impact en cas de compromission : Si l'attaquant vole le credential en mémoire, il ne dispose que de quelques minutes pour l'exploiter. Il ne peut pas l'utiliser pour établir une

persistance à long terme sans devoir repasser par l'étape d'authentification biométrique/
matérielle de l'administrateur légitime.

7. Scénarios d'attaque

Scénario	Fonctionnement traditionnel	Avec notre architecture	Impact / Mécanisme de limitation
1. Phishing d'un utilisateur	Vol du mot de passe + OTP. L'attaquant se connecte.	L'attaquant demande le Passkey.	Échec de l'attaque. WebAuthn est résistant au phishing grâce à la liaison avec le nom de domaine (origin binding).
2. Vol d'un credential en mémoire	L'attaquant exfiltre un token d'API ou un password de DB valide des mois.	L'attaquant exfiltre un credential dynamique JIT.	Impact très limité. Le credential expire de lui-même. Limite résiduelle : exploitation possible dans la fenêtre de temps restante (ex: 30 minutes).
3. Compromission d'un poste administrateur	Accès aux outils d'administration et aux sessions ouvertes.	Accès au poste, mais besoin d'une action matérielle (touch FIDO2) pour une nouvelle tâche.	Impact limité. Le malware peut "rider" une session JIT active, mais ne peut pas exfiltrer un secret permanent.
4. Compromission serveur applicatif	Vol du fichier de configuration et accès complet à la base de données de production.	Vol de l'identité machine (certificat court).	Le serveur ne dispose que des droits strictement nécessaires à l'instant T. Le SIEM détectera l'usage anormal de l'identité machine.
5. Compromission prestataire externe	Exploitation du VPN du prestataire pour rebondir sur le SI interne.	Les prestataires n'ont pas de comptes persistants, uniquement du JIT soumis à approbation interne.	Mouvement latéral bloqué. Pas de compte dormant à exploiter.

Scénario	Fonctionnement traditionnel	Avec notre architecture	Impact / Mécanisme de limitation
6. Compromission IdP (Identity Provider)	L'attaquant forge des jetons (Golden SAML) et accède à tout.	Idem, l'IdP est le cœur de la confiance.	Risque critique résiduel. C'est la limite du modèle. Nécessite une architecture distribuée, des HSM pour l'IdP, et des alertes SIEM spécifiques.

8. Architecture distribuée

Une erreur classique consiste à centraliser tous les accès dans un unique "coffre-fort" de mots de passe, créant un *Single Point of Failure (SPOF)* redoutable. Nous ne proposons PAS un coffre-fort national unique.

L'architecture défendue s'appuie sur la segmentation :

- **Multi-zone et multi-autorité** : Chaque zone de sécurité ou administration conserve l'autorité sur son propre domaine d'identité.
- **Hardware Security Modules (HSM)** : Les clés de signature de l'IdP et du Secret Manager doivent être ancrées dans du matériel pour empêcher leur exfiltration.
- **Séparation des responsabilités (Quorum)** : Les opérations critiques (comme la restauration d'une clé maîtresse) nécessitent l'action cryptographique de plusieurs administrateurs distincts (Shamir's Secret Sharing).

9. Migration des infrastructures existantes

Le principal frein à l'adoption du "Zero Secret" est le poids de la dette technique. Il n'est ni réaliste ni souhaitable de décréter le "remplacement de tout". La migration doit s'opérer par strates, sans rupture d'activité.

1. **Phase 1 : Nouveaux systèmes (Greenfield).** Toutes les nouvelles briques (applications cloud natives) naissent avec l'identité cryptographique par défaut.
2. **Phase 2 : Comptes administrateurs.** Déploiement des Passkeys et du JIT pour les accès de niveau "Tier 0" et "Tier 1" (Active Directory, Hyperviseurs, Réseaux).
3. **Phase 3 : Applications internes.** Intégration via des proxys d'identité (OIDC/SAML) pour les applications existantes compatibles.
4. **Phase 4 : Secrets applicatifs.** Remplacement progressif des chaînes de connexion DB statiques par des credentials dynamiques (ex: via HashiCorp Vault ou équivalent intégré).
5. **Phase 5 : Systèmes legacy compatibles.** Injection automatique de secrets à usage unique pour les vieilles applications qui réclament obstinément un mot de passe.
6. **Phase 6 : Environnements critiques et OT.** Déploiement sur les systèmes industriels avec des validations manuelles multi-acteurs.

Pour les systèmes ne pouvant pas évoluer, le gestionnaire de secrets agira comme un intermédiaire, en réalisant une rotation automatique du mot de passe legacy à haute fréquence, masquant cette complexité à l'utilisateur humain.

10. Proof of Concept (PoC) Biscuits IA

En tant qu'association de loi 1901 dédiée à la cybersécurité et l'intérêt public, Biscuits IA a développé un prototype fonctionnel destiné à illustrer ces concepts de manière tangible.

- **Ce qui est déjà développé** : Un moteur d'authentification FIDO2, un portail de demande d'accès JIT, l'intégration avec un gestionnaire de secrets open-source pour la création dynamique de rôles PostgreSQL.
- **Ce qui est expérimental** : L'intégration des politiques ABAC complexes (basées sur des signaux de télémétrie des endpoints).
- **Ce qui doit encore être audité** : Le code cryptographique de liaison d'identité, la résistance du moteur de politiques face aux attaques par confusion de requêtes.
- **Ce qui n'est pas encore prêt pour production** : La gestion du cycle de vie complet en haute disponibilité et la reprise après sinistre (Disaster Recovery). *À préciser dans la documentation technique du prototype.*

11. Sécurité du prototype

Toute solution de sécurité est une cible. Voici l'analyse des menaces (Threat Modeling) basée sur la méthodologie STRIDE appliquée à notre architecture :

Menace (STRIDE)	Probabilité	Impact	Mesure compensatoire	Risque résiduel
Spoofing (Usurpation)	Faible	Critique	WebAuthn (origin binding), mTLS pour les machines.	Vol d'une clé physique non protégée par code PIN.
Tampering (Altération IdP)	Très Faible	Critique	Signatures HSM, logs immuables (Write-Once).	Compromission profonde de la chaîne de compilation.
Repudiation	Faible	Moyen	Le SIEM trace de l'identité forte jusqu'à l'accès final.	Destruction des logs par un insider très privilégié.
Information Disclosure	Moyenne	Élevé	Les secrets générés expirent très rapidement.	Exfiltration de la donnée via la session légitime.
Denial of Service (DoS)	Élevée	Élevé	Architecture distribuée, cache d'autorisation local.	Blocage de l'IdP empêchant toute nouvelle connexion.
Elevation of Privilege	Moyenne	Critique	Validation systématique JEP. Moteur de règles strict.	Vulnérabilité zero-day dans le Policy Engine.

12. Pourquoi l'État devrait tester cette approche

Cette architecture mérite une expérimentation contrôlée car elle propose une réduction mesurable de la dépendance aux secrets statiques dans les sphères publiques et parapubliques.

Les bénéfices systémiques incluent :

- La réduction drastique de la durée de vie des credentials limitant mécaniquement les fenêtres d'opportunité des acteurs malveillants.
- L'application réelle du principe du moindre privilège, non plus statique, mais dynamique.
- Une capacité de révocation quasi immédiate en cas de compromission avérée (bouton d'arrêt d'urgence).
- L'amélioration de la résilience post-incident (plus de mots de passe massifs à réinitialiser).

13. Proposition de pilote

L'expérimentation doit se faire dans un cadre rigoureux, sans mettre en danger la continuité de service de l'entité publique partenaire.

- **Phase 0 — Audit (4 à 8 semaines)** : Revue du code du prototype Biscuits IA, analyse cryptographique par des tiers, définition du périmètre.
- **Phase 1 — Laboratoire (8 semaines)** : Déploiement en environnement de développement (sandbox), simulation d'attaques Red Team.
- **Phase 2 — Environnement non critique (3 mois)** : Déploiement sur un sous-système interne (ex: accès à un intranet technique non sensible).
- **Phase 3 — Système pilote (3 à 6 mois)** : Intégration sur une base de données de pré-production ou un environnement de prestataires.
- **Phase 4 — Évaluation indépendante (1 mois)** : Rédaction d'un RETEX (Retour d'Expérience) objectif mesurant les KPI.

14. Indicateurs de performance (KPI)

Le succès du pilote sera évalué factuellement via ces métriques de sécurité :

Indicateur	Objectif visé lors du pilote
% de comptes d'administration sans mot de passe	> 90% sur le périmètre cible
Durée de vie moyenne d'un credential privilégié	< 4 heures (idéalement < 1 heure)
Temps moyen de révocation d'un accès	< 5 secondes
Nombre de comptes privilégiés dormants (permanents)	Réduction de 100% sur le périmètre
Taux de réussite des tests de phishing internes	0% de compromission (bloqué par conception)

15. Comparaison des architectures

Cette analyse démontre que l'architecture proposée est une évolution complémentaire aux standards existants, répondant spécifiquement aux menaces APT (Advanced Persistent Threat).

Critère	Mot de passe	Mot de passe + MFA	Passkey / FIDO2	Architecture proposée (JIT + Secrets Dyn.)
Résistance au phishing	Nulle	Moyenne (MFA Fatigue, AiTM)	Forte	Forte
Exfiltration DB	Vulnérable (hash cassables)	Protégé par le 2nd facteur	Immunisé (clé publique uniquement)	Immunisé
Durée de vie du privilège	Permanente	Permanente (session longue)	Permanente (jusqu'à révocation)	Éphémère (Expire seul)
Dommages collatéraux vol session	Accès total continu	Accès continu tant que session active	Accès continu tant que session active	Accès limité à la tâche en cours

16. Souveraineté et dépendances

La notion de souveraineté dans ce projet ne se résume pas à l'origine géographique du code. Elle se définit par :

- **Maîtrise du code** : Capacité à inspecter, recompiler et modifier les composants critiques (privilège de l'open source).
- **Hébergement et cryptographie** : Les clés privées de l'IdP ne quittent jamais le territoire national et résident dans des HSM approuvés.
- **Supply chain** : Analyse systématique (SCA/SBOM) des dépendances logicielles pour prévenir les attaques de type SolarWinds.
- **Auditabilité** : L'absence d'algorithmes propriétaires opaques (*Security through obscurity*) en faveur des standards ouverts (WebAuthn, OAuth2, X.509).

17. Gouvernance et transparence

Une infrastructure gérant l'identité et les accès ne peut reposer sur une confiance aveugle. Le projet s'inscrit dans une gouvernance de sécurité ouverte :

- Soumission du code source à des revues cryptographiques indépendantes.
- Tests d'intrusion réguliers (Pentests) ciblant spécifiquement le Policy Engine.
- Analyse juridique concernant le stockage des preuves d'identité (conformité RGPD / CNIL).
- La posture de Biscuits IA est claire : *Nous acceptons par avance que notre propre système soit attaqué, déconstruit et critiqué par les experts de l'État. C'est la condition de la confiance technologique.*

18. Ce que Biscuits IA demande

Pour lever toute ambiguïté sur notre démarche :

Biscuits IA ne demande PAS :

- Un déploiement national immédiat de ses solutions.
- Un financement commercial (notre statut associatif loi 1901 nous place dans une logique d'intérêt général).
- Une adoption obligatoire remplaçant les systèmes validés par l'ANSSI.
- Une confiance aveugle dans notre technologie.

Biscuits IA demande :

- La possibilité de présenter formellement ce prototype technique à des experts publics compétents (RSSI, DSI, acteurs étatiques).
- Si l'intérêt technique est validé, l'autorisation de participer à une expérimentation contrôlée, auditable et mesurable sur un périmètre restreint.

19. Conditions de réussite

Un passage éventuel à l'échelle nécessitera la validation formelle de nombreux jalons :

- Audit externe et tests d'intrusion (Red Teaming) validés sans vulnérabilité critique.
- Tests de charge pour s'assurer que la génération de certificats éphémères ne crée pas de goulot d'étranglement (latence).
- Tests de récupération (Disaster Recovery) prouvant la capacité à reconstruire les identités en cas de destruction physique des serveurs.
- Validation de l'interopérabilité avec les annuaires existants des administrations.
- Définition stricte d'un plan de sortie (réversibilité totale) garantissant que l'État ne s'enferme dans aucune solution (Vendor lock-in).

20. Conclusion

La transition vers des architectures *Zero Secret* n'est plus une question théorique, mais une nécessité face à l'industrialisation des attaques ciblant l'identité et les accès privilégiés.

La question n'est pas de savoir si l'architecture que nous présentons aujourd'hui est parfaite en tout point dès sa conception. La question est de savoir si elle permet de réduire suffisamment le risque d'exploitation des secrets statiques pour justifier une expérimentation immédiate.

Biscuits IA propose donc une démarche simple : présenter, tester, attaquer, auditer, mesurer et décider sur les résultats.

Bibliographie et Références Normatives

- **ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information) :** Recommandations relatives à l'authentification multifacteur et à la gestion des mots de passe.
- **FIDO Alliance :** Spécifications techniques FIDO2 (WebAuthn / CTAP2).
- **CISA (Cybersecurity and Infrastructure Security Agency) :** Zero Trust Maturity Model.
- **NIST (National Institute of Standards and Technology) :** SP 800-63B (Digital Identity Guidelines) et SP 800-207 (Zero Trust Architecture).
- **ENISA :** Lignes directrices sur la gestion des identités et des accès (IAM) dans les infrastructures critiques européennes.